FACULTAD DE DEFENSA NACIONAL — FADENA
LICENCIATURA EN CIBERDEFENSA | Tecnología Operativa 2026
UNIDAD 4: CONVERGENCIA, IoT Y RIESGOS EN CIBERDEFENSA

AP N°15 — ACTIVIDAD PRÁCTICA

Análisis Arquitectónico IT/OT: Identificación de Vectores de Erosión del Modelo Purdue y Diseño de Arquitectura Segmentada

Documento de Cátedra N°15 — Convergencia IT/OT: Desafíos de Integración y la Industria 4.0

Tiempo estimado	90–120 minutos	**Dificultad**	Intermedia
Herramienta principal	draw.io / diagrams.net (web, sin instalación, sin registro)	**Recurso adicional**	Wireshark — opcional, para análisis de tráfico complementario
Modalidad	Individual, asincrónica	**Entrega**	Exportación del diagrama anotado (PNG) + respuestas escritas en PDF
Archivo de trabajo	base_logistica_sur_arquitectura_itot.xml (provisto por la cátedra en Moodle)	**Documento alineado**	Doc. de Cátedra N°15

ESCENARIO DEL INCIDENTE

Base Logística Sur es una instalación militar ficticia de Comando, Logística y Comunicaciones ubicada en zona costera. En los últimos 18 meses, la dirección del establecimiento adoptó un conjunto de tecnologías de la Industria 4.0 para modernizar sus operaciones: sensores IIoT de temperatura y vibración en los generadores de emergencia, smart meters en cada edificio, un gateway de integración con plataforma cloud del proveedor de mantenimiento predictivo y mejoras en el acceso remoto del contratista de climatización.

El 19 de mayo de 2026, a las 02:47, los sistemas de monitoreo del NOC detectaron cifrado masivo de archivos en la red corporativa IT. Un ransomware del tipo LockBit 3.0 había comprometido el servidor de correo y estaba propagándose lateralmente. El director del establecimiento convocó de inmediato al oficial de Ciberdefensa para una decisión operacional crítica: ¿se puede continuar operando los sistemas de control OT (generadores de emergencia, grupos de bombeo contra incendios, HVAC de la sala de comunicaciones) mientras el equipo IT contiene el ransomware en la red corporativa? El oficial de Ciberdefensa consultó el inventario de arquitectura y respondió: «No puedo garantizar que el OT esté aislado.» El director ordenó el apagado preventivo.

Tu tarea como analista es: (1) verificar la arquitectura IT/OT existente e identificar cuáles vectores de erosión del Modelo Purdue impidieron garantizar el aislamiento; (2) cuantificar cuántas condiciones de la Nota de Ciberdefensa 1 del Doc. N°15 fallaron; (3) diseñar la arquitectura revisada que habría permitido al oficial de Ciberdefensa responder: «El OT está correctamente segmentado. Podemos continuar operando.»

Arquitectura IT/OT existente de Base Logística Sur

La siguiente descripción textual corresponde al diagrama contenido en el archivo *base_logistica_sur_arquitectura_itot.xml*. Los componentes están identificados con letras (A–J) que aparecen en el diagrama.

ID	Componente / Rol	IP / Identificador	VLAN	Descripción y datos relevantes
A	PLCs Siemens S7-300 × 3 (Generadores de emergencia)	192.168.30.10 192.168.30.11 192.168.30.12	VLAN 30	Controlan los tres grupos electrógenos de emergencia que alimentan la sala de comunicaciones, el NOC y la infraestructura crítica. Ciclo de vida estimado: 20 años.
B	RTUs GE D20 × 2 (Bombas contra incendios)	192.168.30.20 192.168.30.21	VLAN 30	Controlan los grupos de bombeo del sistema de agua contra incendios. Conectadas al bus Modbus RTU serial que se accede desde Level 2.
C	HMI Siemens TP1200 (Panel de operación local)	192.168.30.5	VLAN 30	Interfaz hombre-máquina local de los generadores. TeamViewer 15 instalado por el integrador del sistema para soporte técnico remoto. Última revisión de acceso: desconocida.
D	Servidor SCADA InduSoft (Supervisión de proceso)	192.168.20.10	VLAN 20	Servidor de control supervisorio. Tiene habilitado el módulo web de InduSoft para que los supervisores de planta puedan visualizar el estado desde la red IT corporativa (VLAN 10) sin VPN adicional.
E	Servidor PI Historian OSIsoft (Historización de proceso)	192.168.20.5	VLAN 20 + VLAN 10	⚠ El servidor tiene dos interfaces de red simultáneas: eth0 (192.168.20.5) en VLAN 20 (red OT Level 3) y eth1 (192.168.1.50) en VLAN 10 (red IT corporativa) para que el ERP SAP pueda consultar los datos de proceso directamente.
F	Gateway IIoT InHand Networks IR915L (Telemetría de mantenimiento predictivo)	192.168.30.15	VLAN 30	⚠ Instalado en el tablero del generador A. Tiene interfaz Ethernet al bus de campo (VLAN 30) Y módulo 4G/LTE para envío de telemetría a la plataforma AWS IoT del proveedor. Sin APN privado del operador celular.
G	VPN Fortinet FortiGate (Acceso remoto contratista HVAC)	— (tunnel)	—	⚠ El contratista de climatización (empresa externa) accede remotamente mediante VPN SSL que termina su túnel directamente en la VLAN 20 (segmento del Historian, Level 3). No existe jump server ni segmentación adicional entre la VPN y los dispositivos OT.

ID	Componente / Rol	IP / Identificador	VLAN	Descripción y datos relevantes
H	AP WiFi industrial Cisco IE-3000 (Cobertura inalámbrica de planta)	—	VLAN 30	⚠ El access point industrial tiene el SSID «PLANTA_OT» en la misma VLAN 30 que los PLCs y las RTUs. Sin autenticación 802.1X; cualquier dispositivo WiFi puede asociarse y obtener conectividad a la red de campo.
I	Servidor ERP SAP (Red corporativa IT)	192.168.1.10	VLAN 10	Sistema ERP corporativo que consulta datos de proceso directamente al PI Historian (E) mediante su interfaz eth1 en VLAN 10. Red corporativa IT estándar.
J	Active Directory + Email (Infraestructura IT corporativa)	192.168.1.20 / .30	VLAN 10	Controlador de dominio y servidor de correo corporativo. Vector inicial del ransomware: el email server fue el primer sistema comprometido en el incidente del 19/05/2026.

Nota: La arquitectura NO incluye DMZ 3.5 (Zona de Transferencia) entre el dominio OT y el dominio IT. El firewall perimetral de internet separa internet de VLAN 10, pero no existe ningún control equivalente entre VLAN 10 y VLAN 20/30.

OBJETIVOS DE APRENDIZAJE

- Mapear una arquitectura IT/OT real al Modelo Purdue, identificando el nivel correcto de cada componente y las brechas de segmentación existentes.
- Identificar y caracterizar los cinco vectores de erosión del Modelo Purdue (Doc. N°15, Sección 1.2) presentes en una instalación real, con evidencia visual del diagrama arquitectónico.
- Verificar las cinco condiciones de la Nota de Ciberdefensa 1 del Doc. N°15 sobre una arquitectura concreta y determinar cuáles fallan.
- Trazar la cadena de ataque habilitada por la arquitectura existente y vincularla con los modos de integración IT/OT de la Sección 3 del Doc. N°15.
- Diseñar la arquitectura revisada aplicando la DMZ 3.5, los controles de los marcos NIST SP 800-82 Rev. 3 y el modelo de Zones y Conduits del ISA/IEC 62443 (Doc. N°15, Sección 4).

INSTRUCCIONES GENERALES

1. Descargar el archivo *base_logistica_sur_arquitectura_itot.xml* desde la sección AP N°15 en Moodle antes de comenzar.
2. Completar las fases en el orden indicado: primero Predecir (sin abrir el diagrama), luego Verificar (con draw.io), luego Comprender.
3. Para usar draw.io: ingresar a https://app.diagrams.net desde cualquier navegador. No requiere registro ni instalación. Seleccionar «Open existing diagram» y abrir el archivo XML descargado.

4. Para anotar el diagrama en draw.io: usar colores ROJO para los vectores de erosión, NARANJA para la cadena de ataque, y VERDE para los controles de la arquitectura revisada. Agregar etiquetas de texto con el nombre del vector o control.
5. Las capturas de pantalla del diagrama anotado deben mostrar claramente los elementos marcados. Exportar como PNG de alta resolución desde File → Export as → PNG.
6. Las respuestas de la Fase 3 (Análisis) deben referenciar la sección específica del Doc. N°15 que respalda cada afirmación.
7. No discutir los hallazgos del diagrama con compañeros antes de completar la Fase 1 (Predecir).

FASE 1 — PREDECIR (completar ANTES de abrir el archivo XML)

PROPÓSITO

Activar el conocimiento previo y formular predicciones antes del análisis visual del diagrama. Completar esta fase única y exclusivamente a partir de la descripción textual de la arquitectura (tabla de la sección anterior) ejercita el mismo razonamiento que el analista de Ciberdefensa debe aplicar cuando recibe un inventario de activos sin diagrama disponible.

Tarea 1.1 — Mapeo teórico al Modelo Purdue

A partir de la descripción textual de los componentes A–J, completar la siguiente tabla indicando el Nivel del Modelo Purdue al que corresponde cada componente y la justificación. Usar exclusivamente el marco del Doc. N°15, Sección 1.1 (Tabla de niveles 0–4 y DMZ 3.5).

ID	Componente	IP	Nivel Purdue	Justificación (citar el criterio del Doc. N°15)
A	PLCs Siemens S7-300 x3	192.168.30.10-12		
B	RTUs GE D20 x2	192.168.30.20-21		
C	HMI Siemens TP1200	192.168.30.5		
D	Servidor SCADA InduSoft	192.168.20.10		
E	Servidor PI Historian	192.168.20.5 / 192.168.1.50		
F	Gateway IIoT InHand IR915L	192.168.30.15		
G	VPN Fortinet (túnel VPN)	—		
H	AP WiFi PLANTA_OT	—		
I	Servidor ERP SAP	192.168.1.10		

ID	Componente	IP	Nivel Purdue	Justificación (citar el criterio del Doc. N°15)
J	Active Directory + Email	192.168.1.20/30		
K	DMZ 3.5	— (indicar si existe o no)		

Pregunta complementaria: La arquitectura incluye una DMZ 3.5 entre los dominios OT e IT. ¿Verdadero o falso? Justifique indicando entre qué VLANs debería existir según la Sección 1.1 del Doc. N°15.

Respuesta: Pregunta complementaria sobre DMZ 3.5

Tarea 1.2 — Predicciones previas al análisis visual

Responder únicamente a partir de la descripción textual. No abrir el archivo XML todavía.

a) Basándose exclusivamente en la descripción textual, identifique cuáles de los cinco vectores de erosión del Modelo Purdue (Doc. N°15, Sección 1.2) están presentes en la arquitectura. Para cada vector identificado, indicar: (1) el ID del componente (A–J) que lo representa y (2) el nombre exacto del vector según la tabla del documento.

Respuesta 1.2a — Vectores de erosión identificados (antes del diagrama)

b) Según los modos de integración IT/OT de la Sección 3 del Doc. N°15, identifique al menos cuatro modos presentes en la arquitectura de Base Logística Sur y clasifique cada uno por su perfil de riesgo (ALTO / MEDIO) según la tabla del documento.

Respuesta 1.2b — Modos de integración IT/OT presentes y su perfil de riesgo

c) Si Base Logística Sur sufriera el mismo ataque de ransomware que Colonial Pipeline (solo en la red IT corporativa, sin compromiso directo del OT), ¿el oficial de Ciberdefensa podría garantizar técnicamente que el OT estaba aislado? Aplique las cinco condiciones

de la Nota de Ciberdefensa 1 del Doc. N°15 a la arquitectura descrita. Para cada condición, indicar si se verificaría (✓) o fallaría (✗) y por qué.

Respuesta 1.2c — Checklist de la Nota de Ciberdefensa 1 aplicado a la descripción textual

FASE 2 — VERIFICAR (análisis del diagrama en draw.io)

Configuración inicial (completar una sola vez)

1. Descargar el archivo base_logistica_sur_arquitectura_itot.xml desde la sección AP N°15 en Moodle.
2. Ingresar a **https://app.diagrams.net** desde cualquier navegador. No requiere registro ni instalación.
3. Seleccionar «Open existing diagram» y abrir el archivo XML descargado. El diagrama cargará automáticamente la arquitectura de Base Logística Sur.
4. Verificar que el diagrama muestre los 10 componentes (letras A–J) de la descripción textual. Si algún componente no aparece, contactar al docente.
5. Para anotar el diagrama, usar la barra de herramientas de draw.io: cambiar el color de los objetos (Format → Fill Color), agregar etiquetas (doble clic sobre un objeto) y flechas (arrastrar desde el borde de un objeto).
6. Para exportar el diagrama anotado al finalizar cada Etapa: File → Export as → PNG. Incluir cada exportación en el PDF de entrega.

ETAPA A — Inventario visual y mapeo al Modelo Purdue

Abrir el archivo XML en draw.io. Observar el diagrama completo antes de responder.

a) ¿El diagrama incluye todos los componentes A–J de la descripción textual? Listar cualquier componente que no aparezca o que esté representado de forma diferente a la descripción.

Respuesta A.a — Verificación de completitud del diagrama

b) Identificar en el diagrama cuántos «niveles» distintos (zonas horizontales o agrupaciones) hay representados. ¿Cuál es el nivel más alto (Level 4/IT) y cuál el más bajo (Level 0)? ¿Existe una zona rotulada DMZ 3.5 entre el dominio OT y el dominio IT?

Respuesta A.b — Estructura de niveles observada en el diagrama

c) Completar la tabla de inventario visual. Para cada componente, verificar si el nivel Purdue observado en el diagrama coincide con tu predicción de la Tarea 1.1. En la última columna, señalar cualquier diferencia con una ✓ (coincide) o ✗ (difiere).

ID	Componente	Nivel observado en diagrama	Conexiones externas visibles (cruza niveles)	Predicción 1.1 coincide (✓/✗) y observación
A				
B				
C				
D				
E				
F				
G				
H				
I				
J				
K (DMZ)				

ETAPA B — Identificación y anotación de vectores de erosión

Usando las herramientas de draw.io, anotar directamente sobre el diagrama cada vector de erosión identificado. Convención: color ROJO para las conexiones que representan vectores; etiqueta con el nombre del vector según la Sección 1.2 del Doc. N°15.

a) Para cada vector de erosión observado en el diagrama, completar la tabla y adjuntar captura de pantalla del diagrama con la anotación correspondiente en ROJO.

#	Nombre del vector (Doc N°15, Sección 1.2)	Componente(s) involucrado(s) (ID)	VLANs que conecta incorrectamente	Captura de pantalla adjuntada (✓/✗) y descripción del vector en el diagrama
1				
2				
3				
4				
5				

b) El componente F (Gateway IIoT) tiene en el diagrama una representación de su interfaz 4G/LTE. ¿Esta interfaz está conectada a un elemento dentro del perímetro de firewall de la instalación o apunta directamente hacia internet? ¿Qué nivel Purdue bypasea esa conexión? Adjuntar captura del detalle del componente F.

Respuesta B.b — Gateway IIoT y bypass de la DMZ OT

c) Identificar en el diagrama si existe algún control (firewall, IDS, servidor intermediario) representado entre la VLAN 10 (IT) y las VLANs 20/30 (OT). Indicar si la arquitectura implementa alguna forma de DMZ 3.5 o si las redes IT y OT están en el mismo broadcast domain desde la perspectiva de enrutamiento.

Respuesta B.c — Controles entre IT y OT observados en el diagrama

ETAPA C — Cadena de ataque y verificación de condiciones de segmentación

Aplicar filtro de análisis: En draw.io, usando una flecha de color NARANJA, trazar la cadena de ataque más corta desde un adversario externo hasta los PLCs (componente A). Exportar el diagrama con esta anotación y adjuntarlo como Captura C.1.

a) Completar la tabla de la cadena de ataque indicando cada paso que el adversario atraviesa desde el acceso inicial hasta el compromiso de los sistemas de control. Para cada paso, identificar el modo de integración IT/OT explotado (Sección 3, Doc. N°15) y el componente involucrado.

Paso	ID Comp.	Descripción del movimiento	Modo de integración explotado (Sección 3, Doc N°15)	Nivel Purdue origen → destino
1		Acceso inicial		
2		Primer pivoteo		
3		Acceso a dominio OT		
4		Compromiso/incertidumbre final		

b) Verificar sobre el diagrama las cinco condiciones de la Nota de Ciberdefensa 1 del Doc. N°15. Para cada condición, indicar si SE VERIFICA (✓) o FALLA (✗) en la arquitectura actual, con la evidencia específica del diagrama que sustenta la respuesta.

#	Condición (Nota de Ciberdefensa 1, Doc N°15)	✓ / ✗	Evidencia específica en el diagrama
1	¿Puede un paquete originado en Level 4 alcanzar Level 1/2 sin atravesar al menos un firewall con política de denegación por defecto? Si la respuesta es sí, la segmentación no existe.		
2	¿Cómo acceden los contratistas de mantenimiento? ¿La VPN termina en Level 3 con jump server, o tienen acceso directo a la VLAN de control?		
3	¿El servidor historian tiene interfaces de red en la zona OT Y en la zona IT simultáneamente? Si es así, es un bridge potencial entre las dos redes.		
4	¿Hay dispositivos IIoT en Level 1 o Level 2 con conectividad WiFi o 4G además de su conexión de fieldbus?		
5	¿Hay algún gateway o edge device que envía datos de proceso directamente a una plataforma cloud sin pasar por el historian segmentado en la DMZ?		

c) Con base en la verificación anterior, ¿cuántas de las cinco condiciones FALLAN en la arquitectura actual? ¿Cuál es la implicancia directa de ese resultado para la decisión operacional que tomó el oficial de Ciberdefensa la noche del incidente?

Respuesta C.c — Condiciones falladas e implicancia para la decisión operacional

FASE 3 — COMPRENDER (síntesis analítica y diseño de arquitectura revisada)

Las preguntas de esta fase requieren argumentación fundamentada. Cada respuesta debe citar la sección específica del Doc. de Cátedra N°15 que respalda el análisis. Las respuestas que no incluyan referencia explícita a secciones del documento no son elegibles para puntaje completo.

1. De las condiciones falladas en la Verificación (Etapa C, punto b), ¿cuál fue la más determinante para que el oficial de Ciberdefensa no pudiera garantizar el aislamiento del OT durante el incidente de ransomware? Justificar con referencia explícita a la Sección 1.2 del Doc. N°15, vinculando el vector de erosión identificado con la pérdida de certeza sobre el estado del OT. Relacionar con el caso Colonial Pipeline (Apertura del Doc. N°15).

Respuesta 1 — Vector más determinante y su relación con Colonial Pipeline

2. Diseñar la arquitectura IT/OT segmentada revisada para Base Logística Sur. Para cada componente que requiera cambio, especificar: (a) nueva ubicación en el Modelo Purdue (VLAN y nivel); (b) control que elimina el vector de erosión; (c) referencia explícita a la contramedida correspondiente en la Tabla de modos de integración de la Sección 3 del Doc. N°15. Incluir en la respuesta: la nueva arquitectura del Historian (E), la reubicación del Gateway IIoT (F), el nuevo esquema de VPN del contratista HVAC (G) y la ubicación de la DMZ 3.5 con sus controles mínimos. Adjuntar captura del diagrama revisado en draw.io (flechas VERDES para los controles nuevos).

Respuesta 2 — Arquitectura revisada con componentes y controles (+ captura draw.io)

3. Aplicar el modelo de Zones y Conduits del ISA/IEC 62443 (Doc. N°15, Sección 4.2) a la arquitectura revisada propuesta en la Pregunta 2. Definir: (a) las Security Zones de la instalación (mínimo tres: IT, DMZ-OT, OT-Control) con sus activos integrantes; (b) los Conduits entre las zonas con los controles mínimos que los definen (no es solo un enlace de red: citar la definición del documento); (c) el Security Level asignado a la zona que

contiene los PLCs (A) y las RTUs (B), con justificación según el tipo de adversario resistido (Tabla SL1–SL4, Sección 4.2).

Respuesta 3 — Zones, Conduits y Security Levels (ISA/IEC 62443)

4. Verificar las cinco funciones del NIST CSF aplicadas a OT (Doc. N°15, Sección 4.1) contra la arquitectura EXISTENTE de Base Logística Sur (antes de la revisión). Para cada función, indicar si la arquitectura actual la implementa (✓), la implementa parcialmente (—) o no la implementa (✗), con la evidencia del diagrama verificado en Fase 2. Finalmente, seleccionar la función cuya ausencia fue más crítica para el incidente del 19/05/2026 y argumentar la elección.

Respuesta 4 — NIST CSF en la arquitectura existente y función más crítica

5. La Nota de Ciberdefensa 3 del Doc. N°15 establece que en una arquitectura segmentada, la misma brecha de ransomware habría provisto información técnica suficiente para no tener que apagar el OT. Identificar exactamente tres fuentes de información técnica (logs, alertas o registros específicos) que la arquitectura revisada propuesta en la Pregunta 2 habría generado durante el incidente y que la arquitectura actual NO pudo generar. Para cada fuente: (a) nombrar el componente de arquitectura que la genera (ej. «firewall de la DMZ 3.5»); (b) describir qué información específica habría provisto; (c) relacionarla con la función NIST CSF que la genera (Sección 4.1, Doc. N°15).

Respuesta 5 — Tres fuentes de información que la arquitectura revisada habría generado

CRITERIOS DE ENTREGA

Componente de la entrega	Puntaje	Descripción y criterio
Fase 1 — Predecir	20 pts	Tarea 1.1: tabla de mapeo al Modelo Purdue completa con justificación para los 10 componentes + pregunta complementaria DMZ (12 pts). Tarea 1.2: tres predicciones con referencia explícita al Doc. N°15 (8 pts).
Fase 2 — Verificar (Etapa A)	10 pts	Tabla de inventario visual completa. Verificación de completitud del diagrama y mapeo al Modelo Purdue con comparación con predicciones.
Fase 2 — Verificar (Etapas B+C)	30 pts	Etapa B: tabla de cinco vectores con capturas de pantalla en ROJO (15 pts). Etapa C: tabla de cadena de ataque completa con modos de integración y tabla de cinco condiciones verificadas con evidencia (15 pts).
Fase 3 — Comprender (5 preguntas)	40 pts	Preguntas 1 y 3: 7 pts c/u. Preguntas 2, 4 y 5: 8 pts c/u, + 2 pts extra por la captura del diagrama revisado en draw.io (Pregunta 2). Cada respuesta debe referenciar la sección del Doc. N°15 que la fundamenta.
TOTAL	100 pts	Subir UNA sola entrega en PDF con capturas de pantalla integradas del diagrama anotado. Formato del archivo: APELLIDO_AP15_CiberTO2026.pdf